

CNO V: Seguridad Informática



Alumna:

Tristan Rivera Magdalena Yesenia - 174702

Profesor:

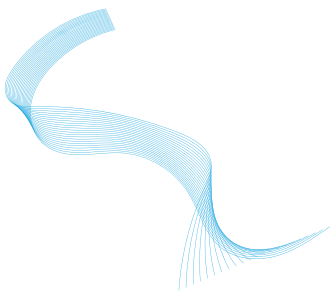
Mtro. Servando López Contreras

Fecha: -----

Practica: ACTIVIDAD 01 - Análisis de un ciberataque real y su impacto empresarial.

Grupo:T46B

Horario: 20:00 - 21:00



Informe de Análisis: El Impacto de NotPetya en A.P. Møller - Mærsk

1. Resumen Ejecutivo

El ciberataque **NotPetya** de 2017 es considerado el ataque informático más devastador de la historia. Aunque inicialmente parecía un ransomware convencional, su arquitectura reveló un objetivo puramente destructivo ("wiper"). Este informe analiza cómo una falla de seguridad en la cadena de suministro de un software contable en Ucrania logró paralizar el comercio marítimo global y obligó a una de las empresas más grandes del mundo, A.P. Møller - Mærsk, a reconstruir su infraestructura digital desde cero en tiempo récord.

2. Ficha Técnica Expandida del Incidente

Categoría	Detalle Técnico y Contextual
Nombre del Malware	NotPetya (alias: Petya.2017, Petna, ExPetr)
Fecha de Inicio	27 de junio de 2017 (Día previo a la festividad de la Constitución en Ucrania)
Atribución	Grupo Sandworm (Unidad 74455 de la GRU rusa, según servicios de inteligencia)
Vector de Entrada	Compromiso de la cadena de suministro mediante el software M.E.Doc
Mecanismo de Propagación	Uso combinado de EternalBlue (CVE-2017-0144) y Mimikatz
Tipo de Amenaza	Wiper (Disfrazado de Ransomware)
Alcance Global	+600 empresas afectadas; 76 terminales de Maersk paralizadas

3. Cronología Detallada: Las 72 Horas que Cambiaron la Industria

Día 1: La Infección

- **08:00 AM:** Un servidor de actualización del software contable ucraniano M.E.Doc es infiltrado. Se inserta un backdoor en la actualización legítima.
- **11:00 AM:** Empresas que utilizan el software descargan la actualización maliciosa. El malware comienza a propagarse lateralmente por las redes internas.
- **12:30 PM:** El malware ingresa a la red de Maersk a través de un solo ordenador en una oficina en Odessa, Ucrania.
- **13:15 PM:** El sistema de Maersk colapsa. El mensaje de "rescate" aparece en miles de pantallas. La gerencia de IT ordena el apagado manual de todos los servidores y la desconexión de cables de red en centros de datos globales.

Día 2 al 10: El Gran Apagón y el "Milagro de Ghana"

Maersk intentó restaurar sus controladores de dominio (el "directorio" que permite que los sistemas hablen entre sí), pero descubrió que todos los backups estaban cifrados.

- **El Hallazgo:** Se localizó un único controlador de dominio sobreviviente en una oficina de Maersk en **Lagos, Ghana**. Una interrupción eléctrica local (apagón) había desconectado el servidor de la red justo antes de que el malware lo alcanzara.
- **La Logística:** Debido a problemas de visa y ancho de banda, un empleado voló desde Ghana hacia Londres con el disco duro en mano para iniciar la reconstrucción global.

4. Análisis mediante el Triángulo de la Seguridad (Modelo CIA)

El impacto se analiza bajo los tres pilares de la seguridad de la información:

Pilar	Impacto	Detalle del Daño
Confidencialidad	Medio	El malware utilizó Mimikatz para extraer credenciales de administrador en texto plano de la memoria (LSASS), comprometiendo todas las identidades de usuario.
Integridad	Crítico	El malware no solo cifró archivos, sino que sobrescribió el <i>Master Boot Record</i> (MBR) y cifró la <i>Master File Table</i> (MFT), haciendo que el disco fuera ilegible incluso si se pagaba el rescate.
Disponibilidad	Total	Maersk perdió acceso a su sistema de reservas, seguimiento de carga y comunicación interna por más de una semana. Los barcos navegaron "a ciegas" y los puertos se congestionaron.

5. Cálculo del Costo Total del Ciberataque (Marco Económico)

El costo total estimado por Maersk fue de entre **\$250 y \$300 millones de USD**. A continuación, se presenta un desglose basado en categorías de impacto económico:

A. Costos Directos (Tangibles)

- **Reparación de Infraestructura:** Adquisición urgente e instalación de 4,000 servidores nuevos y 45,000 laptops.
- **Servicios de Respuesta:** Honorarios de firmas externas de consultoría y respuesta a incidentes (ej. Deloitte) para trabajar 24/7 en la recuperación.
- **Logística de Emergencia:** Costos operativos de mover hardware físicamente (como el vuelo desde Ghana) y establecer centros de mando temporales.

B. Costos de Interrupción de Negocio

- **Pérdida de Ingresos:** Durante el periodo de inactividad, Maersk no pudo procesar nuevas reservas de contenedores (el volumen cayó un 20%).
- **Sobrecosto Operativo:** Pago de horas extras a empleados en puertos que tuvieron que gestionar la carga de forma manual usando papel, lápiz y WhatsApp.

C. Costos Intangibles (Largo Plazo)

- **Daño Reputacional:** Pérdida de confianza de clientes corporativos que dependen de la puntualidad "justo a tiempo".
- **Seguros:** Aumento masivo en las primas de seguros de ciberriesgo tras el evento.

Categoría de Gasto	Estimación de Impacto
Reconstrucción de IT	Alto
Pérdida de Reservas (Revenue)	Muy Alto
Limpieza de Malware y Auditoría	Medio
Gestión de Crisis y RR.PP.	Bajo

6. Lecciones Aprendidas y Mitigación Estratégica

Fallos Críticos Detectados

1. **Red Plana (Falta de Segmentación):** La red de Maersk permitía que un ordenador en Ucrania se comunicara directamente con servidores en EE.UU.
2. **Privilegios Excesivos:** Muchos usuarios tenían permisos de administrador local, facilitando el robo de credenciales.
3. **Higiene de Parches:** El parche de Microsoft (MS17-010) no se había implementado de forma uniforme.

Recomendaciones Post-Incidente

- **Implementación de Zero Trust:** Ningún dispositivo o usuario es confiable por defecto.
- **Estrategia de Backup 3-2-1:** Copias en distintos medios, incluyendo una **offline** (fuera de línea).
- **Seguridad en la Cadena de Suministro:** Auditoría rigurosa de software de terceros.

7. Conclusiones

El caso de Maersk y NotPetya marca un antes y un después en la ciberseguridad industrial. Las conclusiones principales son:

1. **La Ciberseguridad es Resiliencia de Negocio:** Ya no es un problema de IT, sino un riesgo existencial para la operación global.
2. **El Factor Suerte no es una Estrategia:** Maersk se salvó de una pérdida total de datos gracias a un apagón fortuito en Ghana; depender de tales coincidencias subraya la necesidad de backups aislados (*air-gapped*).
3. **Transparencia como Activo:** La decisión de Maersk de ser abierta sobre el ataque ayudó a mitigar el daño reputacional y estableció un estándar de comunicación de crisis en la industria.

8. Glosario de Conceptos Clave

- **EternalBlue:** Exploit de la NSA que aprovecha la vulnerabilidad SMBv1 de Windows.
- **Mimikatz:** Herramienta para extraer contraseñas y hashes de la memoria RAM.
- **Wiper:** Malware cuyo único propósito es destruir datos permanentemente.

9. Referencias y Bibliografía

1. **A.P. Møller - Mærsk.** (2018). *Annual Report 2017*. investor.maersk.com
2. **Greenberg, A.** (2018). *The Untold Story of NotPetya, the Most Devastating Cyberattack in History*. Wired Magazine.
3. **Kaspersky Lab.** (2017). *Schrödinger's Pet(ya): Analysis of the NotPetya attack*.
4. **CrowdStrike.** (2017). *PetrWrap Ransomware Technical Analysis*.

